HOW SAFE IS AI?

Product Requirements Document

A Living Observatory of AI Vulnerabilities

Version 1.0 | March 2026

Executive Summary

- A daily-updated interactive data visualization tracking every known CVE affecting AI systems, presented as biological specimens growing in petri dishes.
- 9 vulnerability categories displayed as a 3×3 grid of petri dishes on a lab bench, each with unique organism colony patterns driven by real data.
- Hosted for free on GitHub Pages with a daily GitHub Action pipeline fetching data from NVD and GitHub Advisory databases.
- Target audience: security professionals, AI practitioners, and the general public wanting to understand AI's growing attack surface.
- Tech stack: React + D3.js frontend, Python data pipeline, zero backend cost.

Problem Statement

AI adoption is accelerating across every industry, but the security implications remain opaque to most people. Vulnerability data exists in scattered databases (NVD, GitHub Advisories, MITRE ATLAS) but is inaccessible to non-specialists. There is no single, visual, continuously updated resource that answers a simple question: how vulnerable are AI systems right now?

This project makes the invisible visible — transforming dry CVE records into an intuitive biological metaphor that communicates threat levels at a glance, while educating viewers about the categories of risk in AI systems.

Product Overview

The Metaphor

Vulnerabilities are presented as biological organisms growing in petri dishes. Each petri dish represents a category of AI vulnerability. Inside each dish, colonies represent affected products (LangChain, TensorFlow, etc.). The visual state of each dish communicates threat level: a bright, overgrown dish signals an active, unsolved problem; a pale, mostly faded dish indicates the ecosystem is responding with patches.

Page Structure

Section 1 — Intro: Three beats above the fold. Why this exists (AI is deployed faster than it's secured). How to read the dishes (size, color, faded vs vivid). Headline stats (total CVEs, critical count, exploited count, patch rate, QoQ trend).

Section 2 — Lab Bench: A 3×3 grid of interactive petri dishes on a warm cream lab bench surface with subtle texture. The grid grows dynamically in rows of 3 as new categories are added via config.

Section 3 — Footer: Methodology explanation, data source credits (NVD, GitHub Advisory, MITRE ATLAS), update frequency, and link to the GitHub repository.

Vulnerability Categories (9 Dishes)

Categories are config-driven via a categories.json file. Adding a new category requires only a config entry — no code changes. The current taxonomy:

#	Category	What It Covers
1	Prompt Injection	Hijacking model instructions via crafted input, jailbreaks, indirect injection
2	Improper Output Handling	XSS, SSRF, code injection when downstream systems blindly trust model output
3	Model Poisoning	Training data corruption, backdoors, adversarial attacks, trojans
4	Data Leakage	PII extraction, training data exposure, model inversion, membership inference
5	Denial of Service	Resource exhaustion, memory/CPU exhaustion, infinite loops, crashes
6	Supply Chain	Malicious packages, unsafe deserialization, compromised dependencies in ML libs
7	Model Theft	Weight exfiltration, model cloning via API queries, unauthorized access
8	Agentic Autonomy	Tool misuse, plugin exploits, sandbox escapes, excessive autonomous agency
9	Vector / Embedding	RAG poisoning, embedding manipulation, semantic space attacks

Data-to-Visual Mapping

Every visual element in the petri dishes is driven by real data. The mapping is designed so threat level is readable at a glance without reading any numbers.

Data Point	Visual Representation
CVE count per product	Colony blob size within the dish
CVE severity	Color intensity (critical = vivid saturated core, low = faint edge)
Number of affected products	Number of distinct colonies in the dish
Actively exploited CVEs	Pulsing bioluminescent glow on that colony
Patched CVEs	Faded / desaturated colonies (treated)
Unpatched CVEs	Vivid / bright colonies (untreated, still a live threat)
QoQ trend growing	Colonies spread toward edges of dish
QoQ trend shrinking	Colonies pull toward center (contained)

Severity maps spatially inside each dish: critical CVEs render at the core/center, high in the mid-ring, medium in the outer area, and low at the faint edges. This spatial mapping enables the hover-highlight interaction in Lab Notes.

Per-Dish Visual Patterns

Each dish has a unique colony pattern that metaphorically represents how that category of attack works. This is both a visual differentiator and an educational device — the lab notes explain why each dish looks the way it does.

Dish	Colony Pattern	Why This Pattern
Prompt Injection	Radiating tendrils from center	Attacks penetrate inward, propagate outward
Output Handling	Random chaotic splatter	Outputs spray unpredictably in all directions
Model Poisoning	Dense dark core, speckled edges	Corruption spreads slowly from within
Data Leakage	Concentric bleeding rings	Data seeps through protective layers
Denial of Service	Aggressive overgrowth filling dish	Resource exhaustion consumes everything
Supply Chain	Scattered multi-colored colonies	Multiple unrelated entry points
Model Theft	Branching veins toward edges	Extraction reaching outward, pulling knowledge
Agentic Autonomy	Central cluster + satellite blobs	Autonomous actions breaking away
Vector / Embedding	Web of connected fuzzy nodes	High-dimensional, uncertain boundaries

Interaction Model

User Action	System Response
Idle	Colonies breathe slowly (~4s cycle), speckle particles drift, ambient glow pulses
Hover a dish	Dish brightens slightly, category name + CVE count tooltip appears
Click a dish	Lab notes panel appears next to the dish; all other dishes fade/blur
Hover severity in notes	Corresponding spatial zone in the dish highlights (critical=core, low=edge)
Hover "Patched" in notes	Faded/desaturated areas of the dish highlight
Hover "Unpatched" in notes	Vivid/bright areas of the dish highlight
Click outside or dish again	Notes dismiss, all dishes return to normal state

Lab Notes Panel

When a dish is clicked, a lab notes panel appears alongside it. The notes have five sections:

Header: Specimen name (category) and last observed date.

About This Specimen: 2–3 sentence plain-English explainer of the vulnerability type. Jargon-free, written for someone who doesn’t know what prompt injection is. Defined per category in the config file.

Why It Looks This Way: Explains the visual metaphor — why this dish has tendrils, splatter, or rings. Ties the colony pattern to how the attack actually works. Defined per category in the config file.

Observations: Total CVE count, severity breakdown as interactive colored indicators, QoQ trend with direction arrow. Hovering severity levels highlights corresponding zones in the dish.

Treatment Status: Patch rate as a progress bar (e.g., "63% patched"). Hovering highlights patched vs unpatched areas in the dish. Includes a note: "The faded regions represent CVEs with known fixes. Vivid areas remain untreated."

Data Pipeline

A GitHub Action runs a Python script daily at 00:00 UTC to fetch, process, and commit fresh CVE data. The frontend reads static JSON files — no runtime API calls, no backend.

Data sources: NVD API (api.nvd.nist.gov) for CVE records; GitHub Advisory Database for open-source AI/ML library vulnerabilities.

Categorization: Hybrid approach — keyword scan of CVE descriptions first (priority-ordered), then fallback to product-to-category mapping, then drop any CVE that doesn’t match. One category per CVE, no duplicates across dishes.

Patch status: Derived from CVE references and GitHub Advisory patched version data.

Date range: 2024-01-01 onwards.

Output: data/cves.json (all CVEs with metadata) and data/stats.json (summary statistics). Committed to the repo; GitHub Pages auto-deploys.

Tech Stack & Cost

Component	Technology	Cost
Frontend	React + Vite + D3.js	Free
Rendering	SVG filters + HTML5 Canvas hybrid	Free
Hosting	GitHub Pages	Free (public repo)
Data pipeline	Python script via GitHub Actions	Free (< 90 min/month of 2,000 free)

CVE data	NVD API + GitHub Advisory DB	Free (public APIs, no keys)
Domain	username.github.io/how-safe-is-ai	Free (custom domain optional)

Total ongoing cost: $0/month. The only cost is the build phase if using Claude Code ($20/month for Claude Pro subscription, cancelable after build).

Visual Design Direction

Theme: Light, scientific, editorial. Warm off-white/cream background (#f5f2eb) resembling a lab bench surface. Colorful petri dishes with vivid organisms. Inspired by real petri dish photography. Not a dark cyberpunk dashboard — this stands out by being bright and colorful in a space dominated by dark mode.

Rendering: SVG filters (feTurbulence for agar grain, feDisplacementMap for organic edges, feGaussianBlur for color bleeding) combined with HTML5 Canvas (metaball-style colony blobs, per-dish pattern algorithms).

Typography: Serif or slab-serif for the intro section (editorial feel). Monospace for lab notes and data elements (scientific precision).

Animations: Subtle and ambient — slow breathing pulse on colonies (~4s cycle), drifting speckle particles across agar surface, bioluminescent flash on critical/exploited CVEs.

Success Criteria

- Site loads and renders all 9 petri dishes with organism colonies driven by sample data.
- Each dish is visually distinct and communicates threat level at a glance (overgrown = dangerous, sparse = contained).
- Patched vs unpatched CVEs are visually distinguishable (faded vs vivid).
- Click a dish → lab notes appear with educational content; other dishes fade.
- Hover interactions in lab notes highlight corresponding zones in the dish.
- Daily GitHub Action pipeline successfully fetches, categorizes, and commits real CVE data.
- Site is live on GitHub Pages with zero ongoing cost.
- Performance: 9 simultaneous canvas animations run at 60fps on modern hardware.